Report Data Protection for Business Monitor

JM0160 Intellectual Property and Privacy, Assignment #1: Privacy & Data Protection Law

Group 16

Rick de Rijk, Gilbert Laanen, Stefan Vonk
Thom Verzantvoort, Patryck Grodek, Tycho van Rooij

Table of contents

1 Introduction and Description **2**
1.1 Learning Benchmarking Tool . . . 2
1.2 Data subjects and applicable regime . . . 2

2 How Are the Data Processed? **3**
2.1 Purpose of the processing . . . 3
2.2 Application of the data protection principles . . . 3
2.2.1 Lawfulness, fairness and transparency . . . 3
2.2.2 Purpose limitation . . . 3
2.2.3 Data minimisation . . . 3
2.2.4 Accuracy . . . 4
2.2.5 Storage limitation . . . 4
2.2.6 Integrity and confidentiality . . . 4
2.2.7 Accountability . . . 4

3 On Which Legal Basis? **4**
3.1 The processing ground relied on . . . 4
3.2 Application of its criteria . . . 5
3.2.1 Organisational evaluation . . . 5
3.2.2 Business Monitor's benchmarking service . . . 5
3.3 Problems with relying on this ground . . . 5

4 Advice **6**
4.1 Alternatives to personal data . . . 6
4.2 Technical and organisational measures . . . 6
4.3 Conclusion on compliance . . . 7

Technology Statement **7**

References **7**

List of Figures

Total word count (Sections 1 to 4, excluding footnotes): 2972

1 Introduction and Description

1.1 Learning Benchmarking Tool

Business Monitor developed the Learning Benchmarking Tool (LBT) to evaluate and compare organisational learning programmes using the four Kirkpatrick levels: Reaction (L1), Learning (L2), Behaviour (L3), and Results (L4).[1]

The original LBT is a proof of concept based on fully synthetic programme- and participant-level data, structured for future use with real organisational data.[2] The MVP demonstrates KPI calculation, benchmarking, and exploratory predictive modelling without processing real participant data. Piloting with real organisational data is identified as a next step.[3]

This assessment considers a deployment option in which Business Monitor administers participant surveys on behalf of participating organisations. The original report envisages organisations submitting aggregated or pseudonymised data and does not specify who runs the surveys.[4] We consider this option because Level 3 measures behaviour months after a programme: the same person must be surveyed again, so someone must keep the link between person and pseudonym (person = ID). If the organisations kept that link, Business Monitor would receive only pseudonymised data. Under this option, Business Monitor would initially process identifiable contact information to invite participants and manage surveys. After collection, participant-level survey and learning data would be pseudonymised for analysis.

The identity-to-pseudonym mapping would be retained only as needed for the survey cycle, including Level 3 follow-up measurements. Identifying information and the mapping would be stored separately from analytical data, with restricted access.[5] These safeguards are assumed for this assessment and would need to be implemented before operational deployment. Identifiers and mappings would be deleted when re-identification is no longer necessary, according to a documented retention policy.[6]

Pseudonymised data are used to calculate programme-level KPIs across L1–L4. The original MVP includes an exploratory prediction model using synthetic data.[7] In the assessed operational scenario, predictive analytics remain limited to programme-level outcomes and KPIs, not individual employee performance, behaviour, or capabilities. This is an assumption: the original model only demonstrates exploratory scenario predictions, not validated predictions on real organisational data.[8]

Programme-level results support cross-organisational benchmarking, consistent with Business Monitor's proposed role as a neutral benchmarking hub.[9] Customer-facing outputs are intended to be aggregated and anonymised.

1.2 Data subjects and applicable regime

The data subjects are the employees who attend the learning programmes evaluated through the LBT. Their contact details are personal data, as are their pseudonymised survey responses and learning measurements. Whether pseudonymised data are personal data depends on whether the party processing them has means reasonably likely to re-identify the individual.[10] Under the assumed operational scenario, Business Monitor would hold the mapping during the survey cycle and the employer knows who attended, so that is the case here. The GDPR therefore applies to the operational scenario, but not to the synthetic-data MVP. No special-category data are intended to be collected (Section 3).

The roles differ per purpose. A controller determines the purposes and essential means of processing; a processor acts only on the controller's documented instructions.[11] The participating organisation decides to evaluate its own programmes, which programmes and participants are included and which data are used, so it is controller for programme evaluation. Business Monitor could be argued to be controller here too, because it writes the survey questions and so shapes which data are collected. We nevertheless treat it as processor: designing a questionnaire is a service delivered for the organisation's purpose, and Business Monitor stays processor as long as the organisation approves the question set and data categories, recorded in the Article 28 agreement. Roles follow from the actual influence on purposes and means, not from the contract label,[12] so if Business Monitor fixed the questions and categories on its own, it would move towards joint or sole control.

[1] (Business Monitor Project Team 2026, 4, 11–12)
[2] (Business Monitor Project Team 2026, 4, 10)
[3] (Business Monitor Project Team 2026, 27–29)
[4] (Business Monitor Project Team 2026, 29)
[5] (GDPR 2016, arts. 4(5), 25 and 32)
[6] (GDPR 2016, art. 5(1)(e))
[7] (Business Monitor Project Team 2026, 12, 27–28)
[8] (Business Monitor Project Team 2026, 12, 27–28)
[9] (Business Monitor Project Team 2026, 6–7)
[10] (GDPR 2016, arts. 4(1) and 4(5) and recital 26; CJEU, Case C-413/23 P EDPS v SRB 2025, paras. 85–87)
[11] (GDPR 2016, arts. 4(7), 4(8), 26(1), 28(3) and 28(10))
[12] (EDPB 2021, pt. I, para. 52)

A processor that determines purposes and means is considered a controller for that processing,[13] so Business Monitor acts as controller for benchmarking where it designs the service and decides how the data are combined. If the participating organisation co-determines these purposes and means, both are joint controllers and must allocate responsibilities between them. Joint control is assessed per operation: a party is a joint controller only for the operations whose purposes and means it determines together with another.[14]

2 How Are the Data Processed?

2.1 Purpose of the processing

The LBT involves five processing operations: survey administration, participant-level analysis, programme-level KPI calculation (L1–L4), programme-level predictive analytics, and cross-organisational benchmarking.[15] Under the assumed operational scenario, the first four support each organisation's programme evaluation, with Business Monitor acting as processor on its behalf. Benchmarking additionally serves Business Monitor's own service across organisations.

2.2 Application of the data protection principles

2.2.1 Lawfulness, fairness and transparency

Processing is lawful if it rests on an Article 6(1) ground and, for special categories, an Article 9(2) exception.[16] This is examined for programme evaluation in Section 3.2.1, for benchmarking in Section 3.2.2, and for alternative grounds and special categories in Section 3.3. Fairness and transparency require participants to understand how their responses are used, particularly for commercial benchmarking.[17] Where contact details come from employers, Article 14 requires information no later than the first communication, subject to applicable exceptions; survey responses collected directly fall under Article 13.[18] Notices must identify the relevant controllers and purposes in clear language, including any further processing.[19]

2.2.2 Purpose limitation

Article 5(1)(b) requires specified, legitimate purposes and restricts incompatible further processing.[20] Benchmarking introduces a distinct commercial purpose beyond an employer's programme evaluation. Under Article 6(4), compatibility depends on the relationship between purposes, collection context, participants' reasonable expectations, data sensitivity, consequences and safeguards.[21]

Statistical processing receives special treatment under Articles 5(1)(b) and 89(1), while Recital 162 describes aggregate statistical results not used for individual decisions.[22] However, statistical safeguards do not automatically authorise commercial reuse. Benchmarking therefore requires a documented assessment of purpose compatibility and an appropriate legal basis.

2.2.3 Data minimisation

Article 5(1)(c) restricts collection to necessary data.[23] Direct identifiers serve survey administration, while analysis uses pseudonymised responses. The original dataset includes location, manager-support ratings and promotion flags.[24] Their necessity must be justified individually; programme-level promotion counts may reduce the need to retain individual flags. Free-text responses should be avoided where unnecessary.

[13] (GDPR 2016, art. 28(10); EDPB 2021, pt. II, para. 150)
[14] (GDPR 2016, art. 26(1); CJEU, Case C-40/17 Fashion ID 2019, para. 74; EDPB 2021, pt. I, paras. 51-53)
[15] Participant-level analysis and KPI calculation are distinguished because only the former directly processes participant-level personal data.
[16] (GDPR 2016, arts. 5(1)(a), 6(1) and 9(2))
[17] (GDPR 2016, art. 5(1)(a) and recital 39)
[18] (GDPR 2016, arts. 13(1), 14(1) and 14(3)(b))
[19] (GDPR 2016, arts. 12(1), 13(1)(a) and (c), 13(3), 14(1)(a) and (c))
[20] (GDPR 2016, art. 5(1)(b))
[21] (GDPR 2016, art. 6(4))
[22] (GDPR 2016, arts. 5(1)(b) and 89(1), recital 162)
[23] (GDPR 2016, art. 5(1)(c))
[24] (Business Monitor Project Team 2026, 33)

2.2.4 Accuracy

Article 5(1)(d) requires data to be accurate and kept up to date, having regard to the purposes for which they are processed.[25] Opinions and self-assessments, such as reaction ratings or Level 3 self-assessments, are recorded to show what the participant thinks, so they are accurate when the stored answer matches the answer given. The response bias that the original report identifies[26] affects the reliability of the LBT results, not accuracy under the GDPR. Factual data, such as department, seniority, location or promotion flags, must be correct; incorrect factual data breach Article 5(1)(d). Follow-up records must also remain correctly linked to their pseudonymous identifiers, as a wrong link would attribute one participant's answers to another.

2.2.5 Storage limitation

Article 5(1)(e) limits retention to what is necessary.[27] Under the assumed operational scenario, identification data and re-identification mappings would be deleted once the necessary follow-ups are complete and re-identification is no longer required. Analytical data remain personal data wherever re-identification is reasonably possible, even after deleting the mapping.[28] Small cohorts and contextual variables increase this risk. The MVP's eight-participant threshold is a data-quality criterion, not proof of anonymity.[29]

2.2.6 Integrity and confidentiality

Articles 5(1)(f) and 32 require appropriate security.[30] Identifiers and re-identification mappings must remain separate from analytical data, with access restricted to authorised survey personnel.

2.2.7 Accountability

Article 5(2) requires controllers to demonstrate compliance.[31] Under the roles in Section 1.2, the participating organisations as controllers must establish a legal basis and conclude an Article 28 data processing agreement with Business Monitor. Business Monitor as processor must act only on documented instructions, secure the data, keep records of its processing and notify the controller of a breach without undue delay.[32] For benchmarking, Business Monitor is controller and carries these duties itself, including records of processing and notifying a breach to the supervisory authority (the data protection authority) within 72 hours.[33] Section 4 addresses the necessary agreements and records.

3 On Which Legal Basis?

3.1 The processing ground relied on

The operational LBT involves two purposes requiring separate legal assessments, with the roles set out in Section 1.2. If the participating organisation merely supplies data to a service that Business Monitor designs for benchmarking, they are separate controllers, and the organisation's disclosure of data for that purpose needs its own legal basis.[34]

For both purposes, legitimate interests under Article 6(1)(f) GDPR is the proposed legal basis. It requires three cumulative conditions: a legitimate interest, necessity of processing, and a balancing assessment demonstrating that participants' interests and fundamental rights do not override that interest.[35] Necessity is interpreted strictly: the controller must check whether the aim can reasonably be achieved by less intrusive means. Recital 47 specifically requires consideration of participants' reasonable expectations. Consequently, legitimate interests cannot be presumed valid merely because the processing benefits the organisation.

[25] (GDPR 2016, art. 5(1)(d))
[26] (Business Monitor Project Team 2026, 17–18)
[27] (GDPR 2016, art. 5(1)(e))
[28] (GDPR 2016, recital 26)
[29] (Business Monitor Project Team 2026, 13–14)
[30] (GDPR 2016, arts. 4(5), 5(1)(f) and 32(1))
[31] (GDPR 2016, art. 5(2))
[32] (GDPR 2016, arts. 28(3), 30(2), 32 and 33(2))
[33] (GDPR 2016, arts. 24, 30(1), 33(1) and 35)
[34] (EDPB 2021, pt. I, para. 70)
[35] (GDPR 2016, art. 6(1)(f) and recital 47; CJEU, Case C-708/18 TK 2019, para. 40 and 46-51, decided under the equivalent provision of Directive 95/46)

3.2 Application of its criteria

3.2.1 Organisational evaluation

Legitimate interest. Participating organisations have a legitimate interest in assessing learning effectiveness and improving training investments. Measuring satisfaction, knowledge acquisition, behavioural application and organisational outcomes supports this objective.

Necessity. Contact details may be needed for survey invitations and follow-ups, while pseudonymised responses may support longitudinal analysis and programme-level KPI calculation. However, necessity must be established for each data category. Anonymous surveys or aggregated measurements may achieve some evaluation objectives with less interference, although they may not support participant-linked follow-ups. The organisation must therefore demonstrate why its chosen data are required rather than merely useful.[36]

Balancing. Employees may reasonably expect evaluation of training they attended, supporting the employer's interest. Nevertheless, the employment relationship creates a power imbalance. Responses concerning behaviour, managerial support or promotion could also affect employees if accessed or interpreted individually. Pseudonymisation, restricted access, limited retention and programme-level reporting reduce these risks but do not eliminate them.

On these assumptions, legitimate interests may support organisational evaluation, provided participation requirements, data necessity and safeguards are assessed and documented. Individual employee assessment or employment decisions would require a separate assessment.

3.2.2 Business Monitor's benchmarking service

Legitimate interest. Business Monitor has a commercial interest in producing comparable learning-effectiveness benchmarks across participating organisations. A commercial interest can qualify under Article 6(1)(f), but does not automatically outweigh participants' rights.[37]

Necessity. Business Monitor must demonstrate why cross-organisational benchmarking requires personal data rather than anonymous programme-level indicators. Pseudonymised participant records may enable more detailed comparisons, but this does not establish their necessity. Where anonymous aggregated inputs can achieve the benchmarking purpose, processing participant-level personal data would be difficult to justify under Article 6(1)(f).[38]

Balancing. Benchmarking creates a greater privacy concern than internal evaluation. Employees may expect their employer to assess training effectiveness, but not necessarily anticipate their responses contributing to another company's commercial service. Small cohorts, contextual variables and organisational knowledge increase re-identification risks. Aggregation and pseudonymisation mitigate these risks, provided anonymity is assessed rather than assumed.

Business Monitor should disclose the benchmarking purpose before processing, document the legitimate interests assessment, and ensure that benchmark outputs cannot reasonably identify participants. The Article 6(4) compatibility assessment discussed in Section 2 remains relevant where data are reused for a different purpose.[39]

On the present facts, legitimate interests for benchmarking is less securely established than for organisational evaluation. It remains conditional on demonstrating that personal data are necessary and that participants' rights do not prevail.

3.3 Problems with relying on this ground

The principal difficulty is demonstrating necessity and a favourable balancing outcome for both purposes, especially commercial benchmarking. Controllers must document their assessments rather than assume that pseudonymisation or transparency alone establishes lawfulness. Participants also have a right to object to processing based on Article 6(1)(f), subject to the conditions in Article 21.[40]

Other Article 6 grounds are less suitable on the stated facts. No specific legal obligation, vital interest or public task has been identified. Article 6(1)(b) concerns necessity for a contract with the data subject; the commercial agreement between Business Monitor and an employer does not itself establish this ground for employee data. Consent is theoretically possible but problematic in employment because it may not be freely given.[41]

The scenario does not intend to collect special-category data. Nevertheless, free-text responses could reveal health information or other categories protected by Article 9(1). In such cases, an Article 6 basis and a valid Article 9(2) exception would both be needed.[42] Explicit consent is one possible exception, but its validity is particularly difficult

[36] (GDPR 2016, art. 5(1)(c) and art. 6(1)(f))
[37] (GDPR 2016, art. 6(1)(f) and recital 47)
[38] (GDPR 2016, arts. 5(1)(c) and 6(1)(f))
[39] (GDPR 2016, art. 6(4) and recital 26)
[40] (GDPR 2016, art. 21(1))
[41] (GDPR 2016, arts. 6(1)(a), 6(1)(b) and 7(4), recital 43)
[42] (GDPR 2016, arts. 6(1) and 9(1)-(2))

to establish in employment. Other exceptions depend on specific conditions and cannot be assumed applicable here. Avoiding unnecessary free-text fields and excluding special-category information is therefore preferable.

Overall, Article 6(1)(f) is a plausible basis for organisational evaluation, subject to a documented assessment. For Business Monitor's benchmarking service, the justification remains uncertain unless the necessity of personal-data processing, compatibility of purposes and effective safeguards can be demonstrated. Anonymous programme-level inputs offer a less intrusive alternative.

4 Advice

4.1 Alternatives to personal data

Business Monitor should minimise personal data processing by using anonymous programme-level data wherever feasible. Participant-level information may be necessary for survey administration, longitudinal follow-ups and calculating certain learning indicators, but directly identifiable records are not required for programme-level predictions or customer-facing benchmarks.[43] Business Monitor should assess whether participating organisations can calculate and submit anonymous programme-level indicators instead of transferring participant records.

Where participant-level processing remains necessary, survey responses should be pseudonymised as early as practicable. Identity data and re-identification mappings must be stored separately from analytical records, with access restricted to authorised personnel.[44] The mapping should be deleted once the survey cycle, including necessary follow-ups, is complete and re-identification is no longer required.[45] However, deletion does not automatically anonymise the remaining records: contextual information may still permit identification.

Unnecessary demographic attributes and unrestricted free-text responses should be avoided. Before releasing benchmark results, Business Monitor must assess whether participants could be identified through small cohorts, rare characteristics or combinations of variables. Aggregation alone does not guarantee anonymity.[46]

For benchmarking, Business Monitor could therefore act as the participating organisation's processor and compute anonymous programme-level aggregates on its instructions, so that only those aggregates enter the benchmark pool. Anonymous data fall outside the GDPR,[47] and the benchmark itself would then need no separate legal basis. The anonymisation step is itself processing of personal data and must be covered by the organisation's legal basis and instructions,[48] and the anonymity of its output must be tested as described above.

4.2 Technical and organisational measures

The operational LBT requires safeguards addressing transparency, retention, security, re-identification and accountability.

First, participating organisations and Business Monitor should clearly distinguish organisational evaluation from cross-organisational benchmarking in their privacy notices. Participants must understand the relevant purposes, controller identities, data categories and intended uses before the applicable processing begins. The commercial benchmarking purpose should not be concealed within a general description of employee training evaluation.[49]

Second, a documented retention schedule should define separate periods for identification data, re-identification mappings, pseudonymised analytical records and programme-level outputs. Identifiers and mappings should be deleted when the final necessary follow-up is complete, with deletion recorded. Analytical records require independently justified retention periods and periodic review. Anonymous outputs may be retained outside the GDPR only where anonymity has been adequately established.

Third, Business Monitor should implement encryption, role-based access controls and access logging. Identifying information and re-identification mappings must remain separate from analytical datasets. Re-identification access should be restricted to personnel administering surveys, while analysts should receive only the data necessary for their tasks.[50]

Fourth, benchmark disclosure controls should include minimum cohort sizes, suppression of small groups and checks for identifying combinations of attributes. The original LBT uses eight participants as a minimum benchmark-readiness criterion, but this was designed for data quality rather than anonymity.[51] The threshold must therefore be

[43] (GDPR 2016, art. 5(1)(c))
[44] (GDPR 2016, art. 4(5))
[45] (GDPR 2016, art. 5(1)(e))
[46] (GDPR 2016, recital 26)
[47] (GDPR 2016, recital 26)
[48] (GDPR 2016, arts. 4(2) and 28(3))
[49] (GDPR 2016, arts. 5(1)(a), 12-14)
[50] (GDPR 2016, arts. 4(5) and 32(1)(a)-(b))
[51] (Business Monitor Project Team 2026, 13–14)

evaluated against actual re-identification risks, including risks in programme-level predictive outputs.

Finally, accountability arrangements must be established before operational deployment. These include documented controller–processor responsibilities, Article 28 agreements for processing on behalf of participating organisations, records of processing activities and data protection by design and by default.[52] Business Monitor and participating organisations should also assess whether a Data Protection Impact Assessment is required, considering the nature, scale and risks of employee-data processing.[53] A DPIA is mandatory where processing is likely to result in a high risk to individuals.

4.3 Conclusion on compliance

The current LBT proof of concept uses synthetic data and does not demonstrate GDPR compliance for an operational service involving real participants. Such deployment would require a documented legal and organisational framework before personal data are processed. On the present facts, the operational LBT cannot yet be regarded as GDPR compliant. Organisational evaluation can be made compliant through a documented legitimate interests assessment, transparency and the safeguards in Section 4. Cross-organisational benchmarking remains doubtful unless necessity and a favourable balance are shown; otherwise it should rely on anonymous programme-level inputs.

Two purposes must be assessed separately, with different roles (Section 1.2): the organisations as controllers and Business Monitor as processor for programme evaluation, and Business Monitor as controller for benchmarking.[54] These roles must be established and documented for each processing activity.

Legitimate interests under Article 6(1)(f) is the proposed legal basis, but its suitability remains conditional.[55] Organisational evaluation may be justified where processing is necessary and proportionate. Commercial benchmarking presents a greater challenge because participants may not reasonably expect their responses to support a service across organisations. A separate, documented assessment must establish necessity, purpose compatibility and a favourable balancing outcome. Transparency and safeguards cannot independently establish lawfulness.

Special-category data should not be collected unless an applicable Article 9 exception and a valid Article 6 basis have been established.[56] Survey design should minimise inadvertent collection.

The recommended approach is conditional deployment. Real participant data should be processed only after responsibilities, lawful bases, retention rules, access controls and disclosure safeguards have been established. If these conditions cannot be met, Business Monitor should restrict the affected activities to genuinely anonymous programme-level data or postpone deployment.

Technology Statement

During the preparation of this work, we used ChatGPT (GPT-5) and Claude (Sonnet 5.5) in order to improve documentation quality, help with reducing the number of words and enhance writing clarity. The following parts of the assignment were affected by AI tool usage: all sections. After using this tool/service, Rick de Rijk, Gilbert Laanen, Stefan Vonk, Thom Verzantvoort, Patryck Grodek and Tycho van Rooij evaluated the validity of the tool's outputs, including the sources that generative AI tools have used, and edited the content as needed. As a consequence, Rick de Rijk, Gilbert Laanen, Stefan Vonk, Thom Verzantvoort, Patryck Grodek and Tycho van Rooij take full responsibility for the content of their work.

References

Business Monitor Project Team. 2026. "Learning Benchmarking Tool: Final Report." Jheronimus Academy of Data Science.

CJEU, Case C-40/17 Fashion ID. 2019. "Judgment of the Court (Second Chamber), Fashion ID GmbH & Co. KG v Verbraucherzentrale NRW eV." Case C-40/17, ECLI:EU:C:2019:629. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62017CJ0040.

CJEU, Case C-413/23 P EDPS v SRB. 2025. "Judgment of the Court (First Chamber), EDPS v Single Resolution Board." Case C-413/23 P, ECLI:EU:C:2025:645. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62023CJ0413.

[52] (GDPR 2016, arts. 25, 28(3) and 30)
[53] (GDPR 2016, art. 35)
[54] (GDPR 2016, arts. 4(7), 4(8), 26 and 28)
[55] (GDPR 2016, art. 6(1)(f) and recital 47)
[56] (GDPR 2016, arts. 6(1) and 9(1)-(2))

CJEU, Case C-708/18 TK. 2019. "Judgment of the Court (Third Chamber), TK v Asociaţia de Proprietari bloc M5A-ScaraA." Case C-708/18, ECLI:EU:C:2019:1064. https://eur-lex.europa.eu/legal-content/EN/TXT/?uri=CELEX:62018CJ0708.

EDPB. 2021. "Guidelines 07/2020 on the Concepts of Controller and Processor in the GDPR, Version 2.0." Adopted on 7 July 2021. https://www.edpb.europa.eu/system/files/documents/2023-10/EDPB_guidelines_202007_controllerprocessor_final_en.pdf.

GDPR. 2016. "Regulation (EU) 2016/679 of the European Parliament and of the Council of 27 April 2016 on the Protection of Natural Persons with Regard to the Processing of Personal Data and on the Free Movement of Such Data, and Repealing Directive 95/46/EC (General Data Protection Regulation)." Official Journal of the European Union, L 119, 4 May 2016. https://eur-lex.europa.eu/eli/reg/2016/679/oj.